

Password Policy

Document Status: Fictional / Sample Policy

Policy Owner: Information Security Department

Version: 1.0

Effective Date: August 20, 2026

Review Cycle: Annual

1. Purpose

This Password Policy establishes minimum requirements for creating, managing, protecting, and changing passwords used to access company systems, applications, devices, and information resources.

The purpose of this policy is to reduce the risk of unauthorized access caused by weak, reused, predictable, or compromised passwords.

This document is a fictional sample created for demonstration and training purposes. It does not represent the actual security requirements of any real organization.

2. Scope

This policy applies to all fictional company employees, contractors, temporary personnel, administrators, and other authorized users who access company technology resources.

It applies to passwords used for:

- Corporate email accounts
- Workstations and laptops
- Internal applications
- Cloud services
- Remote-access systems
- Administrative accounts
- Shared technical systems
- Other company-managed accounts

Where a system provides stronger security controls than those described here, the stronger control should be used.

3. Password Requirements

All standard user passwords must meet the following minimum requirements:

1. Passwords must contain **at least 12 characters**.
2. Passwords must contain at least one uppercase letter.
3. Passwords must contain at least one lowercase letter.
4. Passwords must contain at least one number.
5. Passwords must contain at least one special character.
6. Passwords must not contain the user's first name, last name, username, or company identifier.
7. Passwords must not be obvious sequences such as **123456**, **abcdef**, or similar patterns.
8. Passwords must not be reused across unrelated personal and company accounts.

Users are encouraged to create memorable passphrases that are difficult for other people to guess.

4. Password Expiration

For this fictional policy, standard account passwords expire every **90 days**.

Users will receive an appropriate notification before their password expires.

When a password expires, the user must select a new password that satisfies the current password requirements.

A previously used password must not be immediately reused.

Emergency or administrative accounts may have different expiration requirements when technically necessary, subject to security review.

5. Password Creation Guidance

Users should avoid passwords based on easily discoverable information, including:

- Birth dates
- Telephone numbers

- Home addresses
- Names of family members
- Pet names
- Favorite sports teams
- Company names
- Common words combined with predictable numbers
- Information publicly displayed on social media

A stronger approach is to use a long, unique passphrase combined with the required character types.

For example, users should avoid patterns such as:

CompanyName123!

because predictable company-related passwords may be easier to guess.

Page 2

6. Password Protection

Passwords are considered confidential authentication information.

Users must:

- Never disclose passwords to another person.
- Never send passwords through ordinary email or chat.
- Never write passwords on publicly visible notes.
- Never enter passwords into websites reached through suspicious links.
- Lock their workstation when leaving it unattended.
- Use approved password-management software when provided by the company.

Managers and IT personnel must not request a user's current password.

If technical support requires account verification, an approved alternative verification process must be used.

7. Password Reuse

Password reuse increases the impact of an account compromise.

Company passwords must therefore be unique and must not be reused for personal services such as:

- Social-media accounts
- Shopping websites
- Personal email
- Entertainment services
- Banking or financial services

If a company password is suspected to have been exposed, it must be changed promptly.

8. Password Managers

The fictional company encourages the use of an approved password manager.

A password manager may be used to:

- Generate unique passwords
- Store passwords securely
- Reduce password reuse
- Generate long random passwords
- Assist with password rotation

Users must protect the password manager's master credential with an appropriately strong password and any additional authentication mechanism required by the company.

Users must not store company passwords in unapproved plain-text documents, spreadsheets, browser notes, or other unsecured locations.

9. Multi-Factor Authentication

Where technically available, multi-factor authentication (MFA) should be enabled in addition to a password.

MFA may use an approved authentication factor such as:

- Authenticator application
- Hardware security key
- Approved verification mechanism

- Other company-approved authentication technology

MFA does not replace the requirement to maintain a strong password.

Users must never approve an unexpected MFA request merely because it appears on their device.

Unexpected authentication prompts should be reported to the security team.

10. Compromised Passwords

A user who believes that a company password has been compromised must report the incident to the security team as soon as possible.

Examples of potential compromise include:

- A password entered into a suspicious website
- A password accidentally sent to another person
- A lost device containing an accessible account session
- An unexpected password-reset notification
- An unexpected MFA request
- A notification that an account appeared in a security incident

The security team may force a password reset, revoke active sessions, or temporarily disable an account while investigating.

11. Administrative Accounts

Administrative accounts require additional protection because they can provide elevated access to company systems.

Administrative passwords must:

- Be unique to the administrative account
- Meet or exceed the standard password requirements
- Not be shared between administrators
- Be stored only in approved secure systems
- Not be embedded in scripts or configuration files in plain text

Where available, privileged access should use MFA and additional access controls.

Page 3

12. Service and Technical Accounts

Service accounts may be required for applications, integrations, automated processes, or infrastructure components.

Where technically feasible, service accounts should use:

- Unique credentials
- Strong randomly generated secrets
- Restricted permissions
- Secure credential storage
- Appropriate credential rotation

Service-account credentials must not be included directly in source code, public repositories, documentation, or unsecured configuration files.

13. Password Reset Procedure

When a user forgets a password, the user must use the company's approved password-reset process.

Help-desk personnel must follow an identity-verification procedure before assisting with account recovery.

A password must never be reset solely because a requester claims to be an employee.

Temporary credentials, where necessary, should be issued using an approved secure mechanism and should require replacement as appropriate.

14. Prohibited Practices

The following practices are prohibited under this fictional policy:

- Sharing passwords with coworkers.

- Sharing passwords with managers.
- Sharing passwords with IT personnel.
- Using another employee's credentials.
- Reusing a corporate password on personal websites.
- Storing passwords in publicly accessible files.
- Posting passwords in chat channels.
- Sending passwords through unsecured email.
- Circumventing password controls.
- Attempting to obtain another person's password.

Violations may result in security review and appropriate organizational action.

15. User Responsibilities

Every user is responsible for protecting credentials assigned to them.

Users must promptly report:

- Suspected credential theft
- Lost or stolen authentication devices
- Unexpected password-reset messages
- Suspicious MFA requests
- Unauthorized account activity
- Accidental disclosure of credentials

Users should not attempt to investigate suspected compromise by repeatedly logging into an affected account or changing unrelated credentials without guidance from the security team.

16. Security Team Responsibilities

The fictional Information Security Department is responsible for maintaining the password standard and supporting its implementation.

Responsibilities include:

- Reviewing password requirements periodically
- Monitoring authentication security
- Supporting secure account recovery
- Investigating suspected credential compromise
- Communicating significant policy changes

- Providing password-security awareness training

System administrators are responsible for implementing appropriate technical controls where supported by the relevant systems.

17. Exceptions

A documented exception may be permitted when a technical limitation prevents compliance with a particular requirement.

Exceptions must:

1. Identify the affected system.
2. Explain the technical limitation.
3. Document the associated risk.
4. Identify compensating security controls.
5. Have appropriate security approval.
6. Include an expiration or review date.

Exceptions should be reviewed periodically and removed when no longer necessary.

18. Policy Review

This policy should be reviewed at least annually and whenever significant changes occur to authentication technology, company systems, or security requirements.

The security team may update the policy when necessary to address emerging threats or improve security practices.

19. Acknowledgment

By accessing company systems, users acknowledge that they are expected to protect their authentication credentials and comply with applicable password requirements.

Failure to follow this policy may increase the risk of unauthorized access and may result in appropriate security or administrative action.

End of Fictional Sample Password Policy

Classification: Sample / Fictional

Version: 1.0

Last Reviewed: August 20, 2026